

REQUEST FOR PROPOSAL & STATEMENT OF WORK

Healthcare Information System — MediCare Hospital Network

Client: MediCare Hospital Network | **Vendor:** HealthTech Innovations | **Budget:** \$1,750,000 | **Duration:** 14 months | **Start:** 2026-08-15

1. Project Overview & Goals

MediCare requires a unified Electronic Health Record (EHR) and Patient Portal system covering 8 hospitals and 200 clinics, integrating with lab systems (HL7 FHIR R4), billing (EDI 837/835), and telehealth. Full HIPAA compliance is a hard requirement.

Goals: (1) Single patient record accessible across all sites within 6 months. (2) HIPAA BAA executed and controls implemented before any PHI is loaded. (3) Average EHR load time <2s. (4) Reduce medication errors by 40% via clinical decision support.

2. Scope of Work & MVP

MVP (Month 1–5): Core EHR (patient demographics, encounters, problem list, medications), HIPAA-compliant authentication, and integration with 2 lab systems. MVP complete when 500 real patient records (de-identified) load successfully and clinician acceptance test passes.

Out of Scope: Revenue cycle management beyond claim submission; medical device integration beyond specified lab interfaces; genomics data storage.

3. Work Breakdown & Timelines

ID	Work Item	Timeline	Entry Criteria	Definition of Done / Exit Criteria
WI-001	HIPAA-Compliant Auth & PHI Controls	Month 1–2	HIPAA gap assessment complete; BAAs signed	Role-based access control (RBAC) for 15 clinical roles; audit logs
WI-002	Core EHR — Clinical Records	Month 2–5	WI-001 done; clinical workflow mapped	Patient summary, encounter notes, problem list, medication list
WI-003	Lab & Imaging Integration	Month 4–7	WI-002 done; HL7 interfaces spec'd	Results auto-populated in EHR <5 min of lab release; critical values
WI-004	Patient Portal & Telehealth	Month 5–9	WI-002 done; patient consent workflow	Patient app access; records within 24h of discharge (21st Century Act)
WI-005	Clinical Decision Support	Month 7–10	WI-002 done; clinical content licensed	Drug-drug interaction alerts for 100% of orders; evidence-based
WI-006	Billing & Revenue Cycle	Month 9–12	WI-002 done; payer contracts loaded	EDI 837P/837I claims submitted; ERA/835 auto-posted; denial mgmt
WI-007	Multi-Site Rollout & Data Migration	Month 11–14	WI-001-006 stable; legacy data mapped	All 8 hospitals live; historical patient data migrated with 100% accuracy

4. Legal & Contractual Obligations

4.1 Late Delivery Penalty: \$5,000 per calendar day for any missed milestone. Right to terminate for cause if any milestone is delayed more than 45 days. Termination triggers full refund of milestones not delivered.

4.2 Subcontracting: All subcontractors handling PHI must sign HIPAA-compliant Business Associate Agreements. Vendor requires written consent from Client before engaging any new subcontractor. Offshore subcontracting of PHI-touching work is prohibited.

4.3 Indemnity: Vendor solely responsible for HIPAA breach penalties arising from Vendor's system, code, or process failures. Client indemnifies Vendor against claims arising from clinician misuse of the system. No cap on indemnity for HIPAA violations.

4.4 Intellectual Property: Vendor retains ownership of base EHR platform; Client receives a perpetual, transferable licence. All custom modules (clinical decision support rules, MediCare-specific workflows) are works-for-hire and vest in Client. Source code escrow arrangement required.

4.5 Insurance: Professional Indemnity $\geq$ \$5M; Cyber/HIPAA Liability $\geq$ \$10M; Medical Malpractice (tech E&O;) $\geq$ \$3M. Policy must explicitly cover HIPAA breach notification costs.

5. Security Requirements

5.1 SAST + DAST: SAST (Veracode) required on all code commits; DAST (OWASP ZAP) required before each production release. No code may be released with CVSS $\geq$ 7.0 unresolved. DAST must cover all FHIR API endpoints.

5.2 VAPT: Full VAPT before each major release (Months 5, 9, 14) by a HIPAA-specialised firm. Scope: application, API, network, and social engineering (phishing simulation). VAPT report shared with Client's Privacy Officer.

5.3 HIPAA Security Rule: Complete HIPAA Security Rule risk analysis must be conducted and documented before any PHI is loaded. Technical safeguards (access control, audit controls, integrity, transmission security) must be implemented and tested. Annual risk assessment thereafter.

6. Project Closure

Closure: (1) All WIs complete per DoD. (2) HIPAA risk analysis complete with zero unresolved high risks. (3) All VAPT criticals resolved, third-party attestation provided. (4) Legacy systems decommissioned per plan. (5) Staff training completed (minimum 8 hours per clinical user). (6) 90-day hypercare with 24/7 PHI breach response SLA <1h. (7) Source code escrow funded and tested.